HOSPITAL UNIVERSITARIO SAN RAFAEL E.S.E.

INFORME DE AUDITORÍA TÉCNICA: CIBERSEGURIDAD, CONTINUIDAD Y GESTIÓN DE RIESGOS DE TI

Entidad Evaluada: Hospital San Rafael	**Sector:** Salud y Asistencia Médica
Tipo de Auditoría: Técnica y Regulatoria	**Fecha de Emisión:** Octubre 2026
Normativas de Referencia: COBIT 2019 / Circular 007 Supersalud	**Clasificación:** Confidencial

1. Contexto y Alcance de la Revisión

El presente informe recopila los hallazgos identificados en la infraestructura tecnológica del Hospital San Rafael. La entidad atiende a más de 250,000 usuarios y custodia historias clínicas digitales con información sensible de salud. La auditoría evaluó los controles de seguridad de la información, procedimientos de copias de seguridad (backup), gestión de incidentes de servicio en urgencias y cumplimiento de la regulación de protección de datos personales.

2. Problemas y Vulnerabilidades Críticas Identificadas

Durante las pruebas de vulnerabilidad y entrevistas se evidenciaron las siguientes debilidades operacionales:

• **Problema en Ciberseguridad e Identidades:** La entidad carece de autenticación de múltiples factores (MFA) en el acceso remoto por VPN y correos electrónicos de los médicos, lo cual genera un alto riesgo de infección por ransomware y exfiltración de historias clínicas.

• **Fallas en Copias de Seguridad (Backup):** Se identificó que las copias de seguridad de la base de datos de pacientes no cuentan con pruebas periódicas de restauración, y los respaldos se guardan en el mismo centro de cómputo principal sin sitio de contingencia alterno.

• **Ausencia de Plan de Continuidad (DRP):** No existe un Plan de Recuperación ante Desastres (DRP) documentado ni simulacros de continuidad ante caídas masivas del software asistencial en salas de urgencias y cuidados intensivos.

• **Demoras en la Mesa de Ayuda:** La mesa de ayuda presenta una tasa de retraso del 45% en la resolución de incidentes de red, afectando la agilidad en la facturación y dispensación de medicamentos.

3. Necesidades Estratégicas y Regulatorias Obligatorias

Para subsanar las no conformidades y mitigar sanciones de la Superintendencia Nacional de Salud, la organización:

1. **Requiere** formalizar e implementar de forma prioritaria la Política General de Seguridad de la Información (SGSI) alineada con los procesos COBIT APO13 y DSS05.

2. **Necesita** establecer acuerdos de nivel de servicio (SLA) con el proveedor del software de historia clínica para garantizar tiempos máximos de restablecimiento ante incidentes graves.

3. **Debe** ejecutar simulacros semestrales de restauración de backups para asegurar la integridad de la base de datos hospitalaria.

4. **Es fundamental** capacitar al personal asistencial y administrativo en prevención de ataques de ingeniería social y phishing.

4. Oportunidades de Optimización Tecnológica

• **Oportunidad de Modernización Cloud:** Migrar los respaldos secundarios a una infraestructura en la nube con almacenamiento inmutable para prevenir el secuestro de datos por malware.

• **Automatización del Monitoreo:** Implementar herramientas de monitoreo continuo (SIEM) para detectar intrusiones y accesos anómalos en tiempo real.

• **Potencial de Mejora en el Service Desk:** Habilitar un portal de autoservicio con base de conocimientos para solucionar bloqueos de contraseñas de médicos en turnos nocturnos.

5. Matriz de Procesos COBIT 2019 Recomendados

Código	Proceso COBIT	Dominio	Nivel de Urgencia	Objetivo
APO13	Gestionar la Seguridad	APO	Crítica	SGSI y protección perimetral
DSS05	Gestionar los Servicios de Seguridad	DSS	Crítica	Despliegue de MFA y EDR
DSS04	Gestionar la Continuidad	DSS	Alta	Plan DRP y simulacros de respaldo
DSS02	Gestionar Solicitudes e Incidentes	DSS	Alta	Optimización de la mesa de ayuda
MEA03	Gestionar la Conformidad Externa	MEA	Media	Cumplimiento normativo Supersalud